

****Data Processor Criticized for Lack of Security****

Date: 28-09-2023

****Decision****

Private Companies

Criticism

Supervision / Self-Management Case

Report of Breach of Personal Data Security

The Data Protection Agency has expressed criticism in a case where a data processor, Mindworking A/S, did not ensure appropriate security during the development of a platform (a web application) aimed at real estate agents.

Journal Number: 2021-431-0163.

****Summary****

The Data Protection Agency has made a decision in a case where Mindworking A/S, as a data processor and supplier of a platform for real estate transactions, failed to protect against unauthorized access to personal data on the platform through inspection of the source code (XML code).

****Breach of Personal Data Security****

The information that could be accessed on the platform included details that individual real estate agents had linked to a specific property for sale. This included names of potential buyers and the price they had offered for the property, as well as documents containing personal data. For example, drafts of purchase agreements, which – in addition to various identity details – in some cases also contained CPR numbers. Some of the personal data were already publicly available information from registration portals.

The information could be accessed by users associated with specific sales cases after they had logged in with a username and password. The user could access the information by pressing a function key and activating so-called "Dev tools".

****Lack of Relevant Tests****

The Data Protection Agency states in the decision that personal data should generally not appear in the source code or in the display layer's comment fields. This also applies to information that is not personal data but could compromise processing security – for example, if it is possible to view control parameters for services, certificates, or similar in plain text.

Furthermore, the Data Protection Agency emphasizes that requiring individual users to activate "Dev Tools" in the browser to access the information cannot be considered a security measure. It is the Data Protection Agency's opinion that the functionality of using the relevant function key is a commonly known process for inspecting source code that does not require special skills in IT security.

The Data Protection Agency concluded that the data processor should have conducted relevant tests of the platform before its implementation, as this is a known and elementary error that could and should have been avoided. Thus, Mindworking A/S, as a data processor, violated Article 32 of the regulation by not having taken appropriate organizational and technical measures to ensure a level of security that is appropriate to the risks associated with the processing of personal data.

****Decision****

The Data Protection Agency hereby returns to the case where Mindworking A/S (hereinafter referred to as Mindworking) on November 11, 2021, as a data processor and supplier of a platform for a number of data controllers, reported a breach of personal data security to the Data Protection Agency. Mindworking reported the breach of personal data security after a dialogue with the agency, during which the agency had received a number of reports of breaches of personal data security from real estate agents who had used the platform developed by Mindworking. The Data Protection Agency chose to investigate the raised issue further and initiated a case against Mindworking.

Mindworking and the Data Protection Agency have also been in dialogue both orally and in writing, most recently with Mindworking's response to the agency's hearing on May 22, 2023.

1. ****Decision****

After reviewing the case, the Data Protection Agency finds grounds to express criticism that Mindworking's processing of personal data has not been conducted in accordance with the rules in the General Data Protection Regulation's [1] Article 32, paragraph 1. Below follows a detailed review of the case and a justification for the Data Protection Agency's decision.

2. ****Case Presentation****

Mindworking reported a breach of personal data security on November 11, 2021, following an initial dialogue with the Data Protection Agency.

The report from Mindworking was made based on a number of reports of breaches of personal data security that the Data Protection Agency received from November 8 to November 12, 2021, from a total of 65 data controllers using the platform developed and supplied by Mindworking. Mindworking is the data processor for the data controllers.

On November 4, 2021, Mindworking became aware through an inquiry from one of the real estate agents using the platform that it had been possible for unauthorized persons to access information via the platform. The real estate agent had received an anonymous inquiry from a customer who had pointed out a security hole in the platform. The inquiry indicated that the customer could read data in the source code using a function key, which was not intended for them to access.

Mindworking then initiated an internal investigation and found that a file provided too much data to the individual user of the platform. Mindworking has stated that the incident was caused by a security flaw that Mindworking was unaware of, which is why Mindworking had not previously implemented technical or organizational measures.

measures to prevent this from happening. The platform was put into use in early 2019, and the breach lasted until November 4, 2021, when the incident was discovered, and Mindworking simultaneously corrected the error so that only individuals with the appropriate user profiles could access/extract all data directly from the platform. Mindworking has stated that the users who could unlawfully access information via the platform were sellers of individual properties and buyers/potential buyers related to the specific cases. Users were supposed to be registered as users with access rights to the individual case. Access to the information required that the mentioned users were logged in with a username and password on the platform. Mindworking further stated that access to the information in the source code also required "developer competencies" from the users. They thus had to switch to a correct developer tool, understand a deep data structure, and find graph types to gain access to the information.

In the source code, information could be accessed regarding individual cases, for example, in the form of the real estate agents' own notes regarding individual activities on the property, names of potential buyers and the price they offered for a property, the purchase agreement document, various calculations, annual statements for loans, BBR documents, deadlines regarding deposits and guarantees, and a complete document list that included the creation date of the document and a URL link to the specific document. Mindworking has stated that, among other things, the sales-related documents contained personal data, and it cannot be ruled out that the purchase agreements could have included CPR numbers.

Thus, there was access to information, including personal data, that had already been published in other registers, but in certain cases also to personal data that should not be accessible to unauthorized persons. Mindworking has stated that a comprehensive analysis of the log files in November 2021 did not reveal any suspicious activity. However, Mindworking subsequently clarified that it has not been possible to log who may have accessed the information using the function key, as logging is not a browser functionality. It has thus not been possible to determine whether unauthorized persons accessed the information.

3. Justification for the Data Protection Authority's Decision

The Data Protection Authority, based on what Mindworking has stated, assumes that during the period from early 2019 to November 4, 2021, it was possible to access too much information, including

personal data, regarding individual real estate agents' cases related to a specific property via the platform developed by Mindworking, which the real estate agents used when selling properties. The Data Protection Authority further assumes that it was individuals who were registered as users on the specific sales cases who unlawfully accessed the information, and that access to the information required login on the platform with a username and password and then the use of a specific function key. This made it possible, by inspecting the source code, to access too much personal data, including potentially the names of potential buyers and the price they offered for a property, as well as the content of documents containing personal data, such as purchase agreements, which – in addition to various identity information – could potentially also contain CPR numbers.

3.1. Article 32 of the Data Protection Regulation

According to Article 32, paragraph 1 of the Data Protection Regulation, data controllers and data processors must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risks associated with the data controller's and data processor's processing of personal data.

Thus, the data controller and the data processor have an obligation to identify the risks that the data controller's and data processor's processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks. The Data Protection Authority is of the opinion that the requirement, according to Article 32, for appropriate security will normally imply that as a data controller and data processor, one must ensure that information about data subjects does not become known to unauthorized persons.

Furthermore, the Data Protection Authority is of the opinion that the requirement for appropriate security in Article 32, paragraph 1, will normally imply that all likely error scenarios should be tested and controlled in connection with the development of new applications where personal data about a large number of users is processed, to ensure that unauthorized access to personal data does not occur.

In this context, the Data Protection Authority is of the opinion that personal data should generally not appear in source code or in comment fields of the display layer. This applies, moreover, to all information that can compromise security, such as control parameters on services, passwords, certificates, or similar.

The Data Protection Authority is also of the opinion that pressing a specific function key is a commonly known process for inspecting the source code that does not require special competencies in IT security, and it cannot be considered a security measure that it required the user in the browser to, among other things, "switch to a correct developer tool" to gain access to the information.

On the above basis, the Data Protection Authority finds grounds to express criticism of Mindworking – for not having ensured against, including by conducting relevant tests of the application before its implementation, that unauthorized access to too much personal data could occur by inspecting the source code using a specific function key via the platform – has not taken appropriate measures.

****Organizational and Technical Measures to Ensure a Security Level Appropriate to the Risks Associated with Mindworking's Processing of Personal Data, cf. Article 32, Paragraph 1 of the Data Protection Regulation.****

The Data Protection Authority has particularly emphasized in its choice of sanction that this was a known and elementary error that could and should have been easily avoided, that there could be access to personal data that was not publicly available, including information about the names of other potential buyers, the price they offered for the property, and CPR numbers, and that there were many users on the platform.

Furthermore, the Data Protection Authority has noted that Mindworking rectified the error on the same day they became aware of it.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons in relation to the processing of personal data and on the free movement

of such data and repealing Directive 95/46/EC (General Data Protection Regulation).